

INCIDENT RESPONSE PLAYBOOK

Insider Threat — Data Exfiltration

Aligned to NIST SP 800-61 Rev. 2 | CERT Insider Threat Center Best Practices
Includes: SOC Standard Operating Procedure + Sample Case Study

ORGANIZATION

Crestline Capital Advisors, LLC

Information Security | Compliance & Legal | HR

DOCUMENT ID
CCA-IS-IRP-003
VERSION
1.0
REVIEW CYCLE
Annual

CLASSIFICATION
SIMULATED / TRAINING
EFFECTIVE DATE
2024-12-01
AUTHOR
D. Taylor Jr. — SOC Analyst

Table of Contents

PART I — SOC STANDARD OPERATING PROCEDURE

1. Purpose & Scope	3
2. Guiding Principles — Insider Threat Investigations	3
3. Roles & Responsibilities	4
4. Detection & Behavioral Indicators	4
5. Investigation & Triage	5
6. Containment	6
7. Eradication & Evidence Preservation	6
8. Post-Incident Activity & Regulatory Obligations	7
9. Escalation Thresholds	7

PART II — SAMPLE CASE STUDY

Incident Overview	8
Incident Timeline	9
Evidence Summary	10
Technical Analysis	10
Response Actions Taken	11
Lessons Learned & Recommendations	12

Document	Insider Threat — Data Exfiltration Before Resignation — IR Playbook
Reference	NIST SP 800-61 Rev. 2 CERT Insider Threat Center SEC Regulation S-P FINRA Rule 4370
Applies to	All CCA employees, contractors, and privileged users with access to client data or proprietary systems
Severity	P1 (Critical) if client PII/financial data involved; P2 (High) for internal IP or proprietary data only

1. Purpose & Scope

This playbook defines the standard operating procedure for detecting, investigating, containing, and remediating insider threat incidents — specifically data exfiltration by employees prior to voluntary or involuntary separation — at Crestline Capital Advisors (CCA), a registered investment adviser managing over \$4.2B in assets under management.

Insider threat incidents in financial services carry significant regulatory exposure. Unauthorized transmission of client PII or financial data may trigger obligations under **SEC Regulation S-P** (Safeguards Rule), **FINRA Rule 4370** (Business Continuity), and applicable state privacy laws. If client data is confirmed exfiltrated, the CCA Chief Compliance Officer (CCO) must be notified within **24 hours** of discovery to begin regulatory breach assessment.

2. Guiding Principles — Insider Threat Investigations

Insider threat investigations are fundamentally different from external attack response. The subject is a trusted employee with legitimate system access, making the investigation legally sensitive and requiring careful coordination between IS, HR, Legal, and Compliance before any action is taken that could alert the subject or expose the organization to wrongful termination liability.

Confidentiality first: Investigations must remain strictly need-to-know. Do not discuss the subject's name or activity outside the core investigation team. Premature disclosure can prompt evidence destruction.

Legal hold before action: Before any account changes, device seizure, or confrontation, Legal must issue a litigation hold. Evidence collected without proper authorization may be inadmissible.

No self-help remedies: IS analysts do not confront subjects, access personal devices, or take punitive action. HR and Legal own all direct communication with the subject.

Proportional monitoring: Enhanced monitoring of the subject must be authorized by Legal and documented. Overly broad monitoring of colleagues may create privacy or labor law exposure.

Document everything: Every investigative action, finding, and decision must be timestamped and logged in the case file. Chain of custody for all evidence is mandatory from first collection.

3. Roles & Responsibilities

IS Analyst (Tier 1/2)	Alert triage, UEBA/DLP log analysis, evidence collection, IOC documentation
IS Manager / CISO	Investigation authorization; escalation to Legal/HR; external notification decisions
HR Business Partner	Coordinates with Legal on subject interview, PIP status, and separation logistics
Legal Counsel	Issues litigation hold; advises on monitoring authorization; manages regulatory filings
Chief Compliance Officer	SEC/FINRA breach notification decisions; regulatory liaison; client notification
IT / Sysadmin	Access revocation on HR/Legal direction; forensic image acquisition; device retrieval

4. Detection & Behavioral Indicators

4.1 Technical Indicators (SIEM / DLP / UEBA)

- **DLP alert:** Large volume of sensitive files uploaded to personal cloud storage (Google Drive, Dropbox, OneDrive personal) or emailed to personal address
- **DLP alert:** Bulk download from SharePoint, CRM, or document management system — significantly above user's baseline
- **Wazuh rule 100401:** USB mass storage device connected to workstation — especially outside business hours
- **Wazuh rule 100402:** Bulk file copy to removable media (>50 files in <10 min window)
- **UEBA anomaly:** After-hours login and file access — employee accessing systems outside normal working pattern
- **UEBA anomaly:** Accessing files outside normal job scope (e.g., sales rep pulling HR or finance files)
- **Email gateway:** Large attachment sent to personal or competitor domain from corporate email
- **Proxy logs:** File transfer to cloud upload services (WeTransfer, SendSpace, Mega) from corporate network

4.2 Behavioral / HR Indicators (Non-Technical)

The following non-technical indicators, when combined with technical signals, significantly increase confidence in an insider threat determination. IS analysts do not act on behavioral indicators alone — they are used to contextualize technical findings and inform the risk assessment:

- Employee submitted resignation or is known to be interviewing at a competitor
- Employee recently placed on a Performance Improvement Plan (PIP) or received negative review
- Sudden change in behavior: increased secrecy, working unusual hours, resisting standard IT support
- Expressed dissatisfaction with compensation, management, or company direction
- Known personal financial stress (garnishments, visible distress — reported by manager/HR)

5. Investigation & Triage

5.1 Initial Triage Checklist (Tier 1 — target: 30 minutes)

1	Validate alert	Confirm DLP/UEBA alert is not a false positive. Check if transfer volume and destination are anomalous vs. user's 90-day baseline.
2	Identify subject	Document subject's name, role, department, manager, access level, and current employment status (active, PIP, resignation pending).
3	Scope the data	Identify what data was accessed or transferred. Classify: client PII, proprietary trading data, internal IP, or general business files.
4	Notify IS Manager	Escalate immediately to IS Manager. Do NOT contact HR or subject directly. IS Manager contacts Legal and HR per §3.
5	Legal hold	Legal issues litigation hold on subject's email, file access logs, and any devices before any further action. Document timestamp.
6	Covert monitoring	With Legal authorization, enable enhanced covert monitoring of subject's account activity. Do not alert subject.

5.2 Evidence Collection (Tier 2 — within 24 hours of Legal hold)

- Export DLP alert logs, email gateway logs, proxy logs, and SharePoint/OneDrive audit logs for the subject for the prior 90 days.
- Pull Wazuh event logs for the subject's workstation: USB connections, file copies, after-hours logins, privileged command execution.
- Capture forensic image of workstation (covertly if subject is still active — coordinate with IT for after-hours access).
- Preserve email archive: export subject's sent items, drafts, and deleted items for the prior 90 days.
- Query CRM and document management system for all records accessed or downloaded by subject in prior 90 days.
- Document all evidence with hash values (SHA-256), collection timestamps, and chain of custody form.

6. Containment

Containment in an insider threat investigation must be carefully timed to avoid tipping off the subject before evidence collection is complete. IS does not take containment action without explicit direction from Legal and HR. Premature access revocation may prompt the subject to exfiltrate additional data from personal devices or memory.

- **Before subject notification:** Silently remove elevated permissions and data access rights not required for current role — frame as routine access review if questioned.
- **On separation day (coordinated with HR):** Disable all accounts simultaneously at the moment of HR notification — AD, email, VPN, CRM, trading systems, building access.

- **Simultaneous device retrieval:** IT collects corporate laptop, mobile device, and any issued storage media at the time of separation.
 - **Block personal cloud destinations:** Add confirmed personal cloud storage URLs/IPs to DLP block list and proxy block list.
 - **Monitor for post-separation access attempts:** Enable alerting on any authentication attempt from subject's credentials for 30 days post-separation.
-

7. Eradication & Evidence Preservation

- Retrieve and forensically image all corporate devices issued to subject before any data wipe.
 - Preserve all logs identified in §5.2 to immutable storage. Generate SHA-256 hashes. Complete chain of custody documentation.
 - If data was confirmed exfiltrated to personal cloud: Legal to issue preservation letter to the cloud provider (Google, Dropbox, etc.) and evaluate civil litigation options.
 - Revoke all OAuth tokens, API keys, and third-party system credentials provisioned under subject's identity.
 - Audit all actions taken by subject in privileged systems (CRM, trading platform, document management) in the 90 days prior to separation. Report findings to CCO.
 - Retain all evidence for a minimum of 7 years per SEC Books and Records requirements (17 CFR §275.204-2).
-

8. Post-Incident Activity & Regulatory Obligations

8.1 Internal Review

- Conduct post-incident review with IS, Legal, HR, and CCO within 10 business days.
- Document: root cause, data classification and volume exfiltrated, detection timeline, response actions, and business impact.
- Identify access control gaps: did the subject have more access than required by their role? (principle of least privilege failure?)
- Update DLP rules, UEBA baselines, and offboarding checklist based on findings.

8.2 Regulatory Reporting

If client PII or financial account data was confirmed exfiltrated, CCA must assess reporting obligations under **SEC Regulation S-P** (Safeguards Rule) and applicable state breach notification laws. The CCO, in consultation with Legal, will determine within **72 hours** whether affected clients must be notified. FINRA member firms must also evaluate whether a Suspicious Activity Report (SAR) is required if the exfiltration suggests potential securities fraud or misappropriation of client assets. All regulatory determinations must be documented regardless of whether a filing is made.

9. Escalation Thresholds

Condition	Severity	Action
-----------	----------	--------

UEBA anomaly — after-hours access, no exfiltration confirmed	P3 — Low	Monitor 72h; correlate with HR status; close if no further activity
Confirmed bulk download of internal files — no external transfer	P2 — Medium	Notify IS Manager; Legal hold; evidence collection; HR notified
Confirmed transfer of internal IP or non-client proprietary data	P2 — High	Full playbook; Legal-coordinated containment; litigation hold
Confirmed transfer of client PII or financial account data	P1 — Critical	CCO notified; SEC S-P breach assessment; 72h regulatory clock starts
Evidence of transfer to known competitor or short-seller	P1 — Critical	FBI referral considered; SEC enforcement notification; civil litigation

PART II — SAMPLE CASE STUDY

Operation Silent Exit

Incident Overview

Incident ID	INC-2024-0118
Date Discovered	2024-12-03 Detection period: 2024-11-18 through 2024-12-03 (15-day exfiltration window)
Severity	P1 — Critical (client PII and proprietary portfolio model data confirmed exfiltrated)
Classification	Insider Threat — Deliberate Data Exfiltration Prior to Voluntary Resignation
Subject	K. Okafor — Senior Portfolio Analyst, Equity Strategies Group (11 years tenure)
Systems Affected	SharePoint (client portal), CRM (Salesforce), corporate email, OneDrive
Analyst	D. Taylor Jr. — IS Analyst, Tier 1 / Tier 2
Status	CLOSED — Subject separated 2024-12-09. Evidence preserved. No reportable breach (legal determination). Civil hold active.

Narrative Summary

K. Okafor, a Senior Portfolio Analyst with 11 years of tenure and broad access to CCA's proprietary equity factor models, client portfolio data, and Salesforce CRM records, began a pattern of anomalous data access on November 18, 2024 — three weeks before submitting his resignation on December 6. Over the 15-day window, Okafor downloaded 847 files from SharePoint and the CRM, transferred 143 files to his personal Google Drive account, and emailed 12 attachments (including proprietary model spreadsheets) to a personal Gmail address.

The pattern was not detected in real time. A weekly DLP digest report surfaced an anomalous upload volume on December 3 during routine IS review. Investigation confirmed the exfiltration was deliberate: Okafor's access volume was 1,240% above his 90-day baseline, concentrated in files he had not accessed in his normal workflow. Wazuh logs also showed two after-hours USB connections to his workstation — on November 21 and November 29 — neither of which corresponded to any approved IT activity.

IS notified Legal immediately. A litigation hold was issued on December 3. Okafor submitted his resignation three days later, citing a 'new opportunity' — consistent with the hypothesis that he was joining a competitor. Legal coordinated with HR to time the separation for December 9, allowing IS to complete forensic imaging of his workstation before his final day. All accounts were revoked simultaneously at the moment of HR notification. Legal is evaluating civil options. No SEC reportable breach was declared — Legal determined the probability of client harm was low based on the nature of the data accessed.

Incident Timeline

Date / Time	Actor	Event
11-18, 09:14	K. Okafor	First anomalous SharePoint session: 94 files downloaded in 47 minutes across client portfolio folders outside Okafor's assigned accounts.
11-18, 11:30	K. Okafor	OneDrive sync client used to transfer 94 files to personal Google Drive (authenticated via personal browser session on corp workstation).
11-21, 19:47	K. Okafor	After-hours workstation login. Wazuh rule 100401 fires: USB mass storage device connected (WD My Passport, S/N 4A7F2C). 61 files copied.
11-25 – 12-01	K. Okafor	Continued daily SharePoint and CRM downloads. Cumulative file count reaches 623 across 9 sessions. Access concentrated in equity model templates and client contact exports.
11-29, 20:12	K. Okafor	Second after-hours USB event. Wazuh rule 100401 fires again. Same device S/N. 82 files copied. Wazuh rule 100402 fires: bulk copy (>50 files in <10 min).
12-01, 08:45	K. Okafor	12 emails sent from corporate email to personal Gmail (k.okafor.personal@gmail.com). Attachments include: EquityFactorModel_v7.xlsx, ClientListQ4_2024.csv.
12-03, 09:00	DLP System	Weekly DLP digest report flags Okafor's upload volume: 143 files to external cloud destination in 15 days. 1,240% above 90-day baseline.
12-03, 09:45	D. Taylor Jr.	IS Analyst reviews DLP digest. Validates anomaly against proxy logs and SharePoint audit trail. Confirms deliberate exfiltration pattern.
12-03, 10:15	D. Taylor Jr.	IS Manager and Legal notified. Investigation initiated under §5.1 triage protocol.
12-03, 11:00	Legal	Litigation hold issued. Evidence preservation begins. HR notified (need-to-know only — Okafor's direct manager not informed).
12-03 – 12-06	IS / IT	Covert forensic imaging of LRMC-WS-0334 completed after hours. 90-day log exports completed. Evidence hashed and chain of custody documented.

12-06, 14:30	K. Okafor	Subject submits voluntary resignation via email. States 'exciting new opportunity.' Two-week notice given.
12-09, 10:00	HR / Legal	Separation meeting held. All accounts (AD, email, VPN, CRM, SharePoint, trading systems, building access) revoked simultaneously at 10:00 AM. Corporate devices retrieved.
12-09, 10:05	IS	Post-separation monitoring enabled: alerts on any authentication attempt using Okafor's credentials for 30 days.
12-12, 11:00	Legal / CCO	Breach risk assessment completed. No SEC Regulation S-P reportable breach declared. Civil litigation hold remains active. File retained per 17 CFR §275.204-2 (7-year minimum).

Evidence Summary

Source	Evidence	Significance
DLP Report	143 files uploaded to drive.google.com/personal – 11/18 to 12/01	1,240% above 90-day baseline. Primary detection signal.
Proxy Logs	Outbound HTTP POST to drive.google.com – 9 sessions over 15 days	Timestamps match SharePoint download sessions within minutes.
SharePoint Audit	847 file downloads by user kokafor@crestlinecapital.com – 11/18 to 12/01	Files outside assigned accounts: client contact exports, model templates.
Email Gateway	12 emails to k.okafor.personal@gmail.com with attachments – 12/01	EquityFactorModel_v7.xlsx, ClientListQ4_2024.csv confirmed in logs.
Wazuh 100401	USB device WD My Passport S/N 4A7F2C – 11/21 19:47 and 11/29 20:12	After-hours connections. Device not issued by IT.
Wazuh 100402	Bulk file copy event: 82 files in 7m 14s on 11/29	Mapped to removable media. MITRE T1025 (Data from Removable Media).
Disk Image	CCA-WS-0334 forensic image – SHA-256: e7f3a9...2b18 (truncated)	Acquired 12/05 after hours. WD My Passport not found on premises.

All evidence hashed at collection. Chain of custody forms filed in case INC-2024-0118 legal hold folder.

Technical Analysis

Wazuh Detection Rules — Insider Threat Coverage

Two custom Wazuh rules contributed to evidence building (neither fired a real-time P1 alert — both were identified in post-detection log review, highlighting a detection gap addressed in recommendations):

```
7200
(?i)(removable|usb|mass storage)
USB mass storage device connected to workstation
policy_violation,data_loss,T1025,

100401
win.eventdata.driveLetter
same_id
600
50
Bulk file copy to removable media: 50+ files within 10-minute window
policy_violation,data_exfiltration,T1025,
```

UEBA Behavioral Analysis

Retrospective UEBA analysis showed three clear behavioral deviations from Okafor's 90-day baseline:

Metric	Baseline (90-day avg)	Incident Period	Deviation
Files downloaded/day	12.3	56.5	+360%
External transfers/week	0.4	19.1	+4,675%
After-hours logins/mo	1.2	8.0	+567%
Files outside job scope	3.1/wk	47.2/wk	+1,423%

The UEBA deviations were not surfaced in real time because CCA lacked automated UEBA alerting — the DLP weekly digest was the only aggregated behavioral signal reviewed. This is the primary detection gap identified in this investigation.

Response Actions Taken

Detection	DLP weekly digest surfaced anomalous upload volume on 12/03 — 15 days after exfiltration began. IS analyst manually correlated proxy, SharePoint, and email gateway logs to confirm deliberate pattern.
Notification	IS Manager and Legal notified within 30 minutes of analyst confirmation. HR notified on need-to-know basis. CCO briefed same day.
Legal Hold	Litigation hold issued 12/03 at 11:00 AM. Subject's email, SharePoint, CRM, and workstation data preserved. No punitive action taken prior to Legal authorization.
Evidence	Forensic image of CCA-WS-0334 acquired covertly on 12/05 after hours. 90-day log exports from DLP, proxy, SharePoint, email gateway, and Wazuh completed and hashed. Chain of custody documented.
Containment	Covert permission reduction 12/04–12/08 (framed as routine access review). Simultaneous full account revocation across all systems on 12/09 at separation. All corporate devices retrieved.
Monitoring	Post-separation authentication alerting enabled. No credential reuse attempts detected in 30-day monitoring window.
Regulatory	CCO and Legal completed SEC Regulation S-P breach risk assessment 12/12. Low-probability-of-harm determination. No client notification required. FINRA SAR evaluation: no filing warranted. All determinations documented per retention policy.

Lessons Learned & Recommendations

What Worked Well

- Legal coordination was exemplary — litigation hold was issued the same day as IS notification, preserving full evidentiary chain of custody.
- Covert forensic imaging before separation maintained evidence integrity without alerting the subject.
- Simultaneous multi-system account revocation on separation day prevented any post-notification data access.
- Wazuh USB rules (100401/100402) logged both after-hours events with device serial numbers — critical evidence for the civil hold.

Gaps Identified

- **15-day detection delay:** The exfiltration ran undetected for 15 days because DLP alerts were reviewed weekly rather than generating real-time notifications. This is the most significant gap.
- **No automated UEBA alerting:** Behavioral deviations of 1,240%+ above baseline were not surfaced until manual review. A real-time UEBA platform would have flagged this within 24–48 hours of onset.
- **Overly broad SharePoint access:** Okafor had read access to client portfolios outside his assigned accounts due to a role misconfiguration. Least-privilege enforcement was inadequate.
- **No DLP block on personal cloud:** Uploads to drive.google.com personal accounts were logged but not blocked. A block policy for personal cloud destinations would have stopped the primary exfiltration channel.
- **USB use not blocked by policy:** No Group Policy restricted USB mass storage on analyst workstations. USB access should be disabled by default and require IT approval.

Recommendations

R-01	HIGH	Convert DLP digest from weekly to real-time alerting. Any single session exceeding 50 file transfers to an external destination triggers immediate IS notification.
R-02	HIGH	Deploy a dedicated UEBA platform (e.g., Microsoft Sentinel UEBA, Splunk UBA, or Varonis) to baseline user behavior and alert on statistically significant deviations in real time.
R-03	HIGH	Block USB mass storage on all non-IT workstations via Group Policy. Require IS ticket for temporary exception. Log all approved USB events with device serial number.
R-04	HIGH	Implement DLP block policy for personal cloud storage destinations (Google Drive personal, Dropbox personal, WeTransfer) from corporate network and endpoints.
R-05	MEDIUM	Conduct quarterly access reviews for all users with access to CRM, client portal, and proprietary model repositories. Apply least-privilege — access should be scoped to assigned accounts only.
R-06	MEDIUM	Add IS to the HR offboarding trigger workflow. Any resignation, PIP initiation, or involuntary separation should auto-notify IS within 1 business hour for access review.

R-07	LOW	Evaluate data classification and DRM (Digital Rights Management) for the highest-sensitivity files (client contact exports, factor models). Apply read-only + watermark policy to prevent silent copy.
-------------	------------	--

This document was produced as part of a cybersecurity home lab portfolio project. Crestline Capital Advisors is a fictional organization. All incidents, individuals, and data are simulated for training and demonstration purposes. No real client, financial, or personally identifiable information is contained herein.